Week 15 Cloud Security Standards and Identity and Access Management (IAM)

06016421 IT Infrastructure Security
by P. Sumet, IT/KMITL

Credit: https://www.pluralsight.com/resources/blog/cloud/compliance-frameworks-for-cloud-security

Compliance Frameworks in Cloud Security

- International Organization for Standardization (ISO)
  - ISO 27001
  - ISO 27017
  - ISO 27018
  - ISO 17788
  - ISO 17789
- NIST Cybersecurity Framework
- CIS Controls ; CIS = Center for Internet Security
- Federal Risk and Authorization Management Program (FedRAMP)
- CSA Cloud Controls Matrix (CCM)
- CSA Security, Trust, Assurance, and Risk (STAR)



Credit: https://www.pluralsight.com/resources/blog/cloud/compliance-frameworks-for-cloud-security

ISO

- ISO 27001
  - Lays a foundation for creating and maintaining a robust security program in the cloud. It includes requirements and best practices focusing on:
    - Risk assessment
    - Asset management
    - Access control
    - Incident response
    - Continuous monitoring and review
- ISO 27017 :
  - This standard offers guidance for implementing security controls for cloud services. It emphasizes the distinct security aspects and risks related to cloud services.
- ISO 27018 :
  - This standard offers guidance on safeguarding personal information in the cloud. This focuses on privacy concerns associated with the information cloud service providers process.
- ISO 17788 :
  - This standard offers an overview of cloud computing terms and definitions. It helps businesses speak the language and make well-informed choices about cloud adoption and security approaches.
- ISO 17789 :
  - This standard offers guidance on cloud service-level agreements (SLAs). It presents advice for creating SLAs between cloud service providers and clients that clarify service security expectations, roles, and responsibilities.



Credit: https://www.pluralsight.com/resources/blog/cloud/compliance-frameworks-for-cloud-security

NIST Cybersecurity Framework

- Identify: Understand and manage cloud-related cybersecurity risks to guarantee compliance
- Protect: Set up safety measures to guarantee the confidentiality and availability of cloud resources and data
- Detect: Set up measures to spot cybersecurity events and irregularities
- Respond: Draft and implement security incident response plans for issues in your cloud infrastructure
- Recover: Restore systems and data to normal status following a security incident. Understand what happened and set up preventative measures.



Credit: https://www.pluralsight.com/resources/blog/cloud/compliance-frameworks-for-cloud-security

CIS Controls

- The Center for Internet Security (CIS) Controls are a collection of best practices to help organizations improve their cybersecurity posture. While they're not focused on cloud security, they're often used to enhance security and compliance in cloud settings.
- The CIS Controls framework includes 18 main security controls. To determine which of these is most relevant to your cloud environment (and how to interpret and apply them), CIS provides a Cloud Companion Guide. Use this to map out your controls, decide metrics for each control, and determine the results you want.

Credit: https://www.pluralsight.com/resources/blog/cloud/compliance-frameworks-for-cloud-security

Federal Risk and Authorization Management Program (FedRAMP)

- Preparation:

  CSPs undergo a readiness assessment to determine if they're ready to pursue FedRAMP authorization.

- Authorization:

  CSPs are given a thorough security review, which involves examining their cloud systems, controls, and policies. They receive a provisional authorization to operate (P-ATO) or an authorization to operate (ATO) based on the cloud service's risk level.

- Continuous monitoring:

  CSPs must maintain their system with security measures such as vulnerability scans, rapid incident solutions, and security event records. The CSP will undergo regular evaluations.

Credit: https://www.pluralsight.com/resources/blog/cloud/compliance-frameworks-for-cloud-security

Compliance Frameworks in Cloud Security

- CSA Cloud Controls Matrix (CCM)
  - The Cloud Security Alliance (CSA) Cloud Controls Matrix (CCM) v4.0 includes 197 control objectives and related control requirements broken into 17 cloud security domains. It aligns with other standards, such as ISO 27001 and the NIST Cybersecurity Framework.
  - Similar to the CIS controls, you can use the CSA CCM as a model and make a list of the requirements specified. From there, you can determine how your organization will meet those requirements. The CSA also has an implementation guide that can be useful to understand how to navigate these controls.
- CSA Security, Trust, Assurance, and Risk (STAR)
  - The Cloud Security Alliance STAR program helps organizations evaluate CSPs to make well-informed choices.
  - As part of this program, a certifying body evaluates and reviews a CSP's security methods. CSPs compliant with popular security methods earn a STAR certification. Looking for vendors with this certification can reassure you their cybersecurity methods are up to par.

Credit: https://cloudsecurityalliance.org/artifacts/security-guidance-v5

Security Guidance for Critical Areas of Focus in Cloud Computing v5

CSA - Cloud Security Domains Covered:

- Cloud Computing Concepts and Architectures
- Cloud Governance
- Risk, Audit, and Compliance
- Organization Management
- Identity and Access Management
- Security Monitoring
- Infrastructure and Networking
- Cloud Workload Security
- Data Security
- Application Security
- Incident Response and Resilience
- Related Technologies and Strategies

Credit: https://www.pluralsight.com/resources/blog/cloud/compliance-frameworks-for-cloud-security

Best practices for cloud security compliance

- Train and educate employees
- Identify the relevant compliance regulations
  - Your teams need to know how to work in the cloud. But even more importantly, they need to know how to work in the cloud securely. To comply with your organization's chosen cloud security framework(s), everyone working closely with the cloud should understand how to:
    - Set up access controls
    - Encrypt data
    - Authenticate requests for data
    - Safely move data to and from the cloud
    - Handle protected user data
    - Securely share data with authorized third parties
    - Respond to security incidents
- Develop an understandable cloud security policy



Credit: https://www.getastra.com/blog/compliance/nist/nist-cloud-security/

NIST Cloud Security Standards

- NIST cloud security refers to the standards, policies, and best practices put forward by the NIST to efficiently manage cloud cyber security risks.
- NIST standards concerning cloud security include:
  - NIST SP 800 – 144 : Key guidelines for maintaining security & privacy in public clouds.
  - NIST SP 800 – 145 : Defines cloud computing, its characteristics, and its service & deployment models.
  - NIST SP 800 – 146 : Cloud systems along with when & how to use them are explained.
  - NIST SP 800 – 53 : Provides security controls for NIST CSF implementation.
  - NIST SP 800 – 210 : Provides access control guidance for different cloud delivery models.
  - NIST Cyber Security Framework : Provides guidelines to help reduce cybersecurity risks.
  - NIST Cloud Computing Resources : Dedicated catalog for cloud computing resources.



Credit: https://www.getastra.com/blog/compliance/nist/nist-cloud-security/

Who Does NIST Cloud Security Apply To?

- Frameworks, guidelines, and security controls put forward by NIST are ideal for all companies having assets in the cloud. Most companies today have multiple cloud assets in the form of data, applications or both, therefore making implementation of the best cloud security measures integral.
- Following NIST security controls such as NIST SP 800-53, NIST SP 800 -145, and others ensures that security measures apt for your cloud assets are applied for optimal protection. This usually includes risk assessments, data encryption, installation of firewalls, and more.

Credit: https://www.nist.gov/publications/guidelines-security-and-privacy-public-cloud-computing

NIST SP 800–144

Title – Guidelines on Security and Privacy in Public Cloud Computing

The public cloud's security and privacy challenges are addressed in the document. Recommendations for organizations for data & application outsourcing to public cloud platforms.

NIST SP 800-144 is mainly geared toward decision-making executives, information officers, and system managers. It also mentions an exhaustive list of other SP NIST publications that directly relate to cloud computing and can be used in conjunction with NIST SP 800-144.

Key guidelines mentioned include:

- Planning of security and privacy components of cloud computing solutions carefully before implementation.
- Detailed knowledge and understanding of the public cloud computing platform offered by the provider.
- The public cloud computing solution should satisfy the organizational security and privacy criteria.
- Accountability over the privacy and security of applications and data in the public cloud platform should be maintained.

Credit: https://csrc.nist.gov/pubs/sp/800/145/final

NIST SP 800–145

Title: The NIST Definition Of Cloud Computing

The special publication defines cloud computing, its five essential characteristics, three service models, and four deployment models. Broad comparisons of cloud services within the cloud are mentioned.

Service models include SaaS (software as a service), PaaS (Platform as a service), and IaaS (Infrastructure as a service). Deployment models for the cloud are private, community, public, and hybrid.

NIST Cloud Computing Definition

Cloud computing is a model for enabling convenient, on-demand network access to a shared pool of configurable computing resources like networks and applications that can be rapidly bought and used with minimal management effort or service provider interaction.

NIST Vital Cloud Computing Characteristics

- On-demand self-service: Users can provision cloud computing capacities based on unilateral requirements.
- Broad network access: Cloud capabilities are available over the network through daily-use devices like laptops and mobile phones.
- Resource pooling: Resources of the cloud platform serve multiple consumers dynamically according to their demand.
- Rapid elasticity: Cloud platforms provide a high level of resource scalability to meet user requirements.
- Measured service: Cloud platforms automatically control and optimize resource use with a pay-per-use policy.



Credit: https://csrc.nist.gov/pubs/sp/800/146/final

NIST SP 800–146

Title: Cloud Computing Synopsis and Recommendations

Cloud systems are explained in the guide and suggestions for IT professionals are provided. The standard mentions how and when cloud computing is ideal for an organization.

NIST SP 800 – 146 explains different cloud deployments & technical characteristics like cloud performance, reliability, and security concerns.



Credit: https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final

NIST SP 800–53

Title: Security and Privacy Controls for Federal Information Systems and Organizations

NIST SP 800–53 mentions specific security controls to implement NIST CSF for federal organizations. Implementing the security controls is valuable for all organizations however, it mainly targets federal compliance.

The security controls help determine the requirements for securing federal agencies with various impact levels like low-impact, moderate-impact, and high-impact.

The following security controls are relevant for organizations in the cloud:

- Access Control
- Audit and Accountability
- Configuration Management
- Identification and Authentication
- Risk Assessment
- Incident Response



Credit: https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-210.pdf

NIST SP 800–210

Title: General Access Control Guidance for Cloud Systems

This special publication was released to address appropriate access control measures for different cloud delivery models such as:

- Infrastructure-as-a-Service (IaaS)
- Platform-as-a-Service (PaaS)
- Software-as-a-Service (SaaS)

The document focuses on the technical features of access control without considering the deployment model of the cloud (hybrid, private, public). It provides access control guidance for various components of the cloud such as network, data, APIs, and privilege management.



Credit: https://www.getastra.com/blog/security-audit/nist-security-audit/

NIST Cyber Security Framework

The NIST Cyber Security Framework was introduced with the aim of reducing cybersecurity risks for organizations of varied sectors and sizes. It does not provide specific security controls however which is done through special publications. It enables easy customization of cybersecurity practices based on individual company requirements.

NIST 800-53 among other NIST special publications provide security controls for implementing NIST CSF. It consists of three main components:

- Core: Set of high-level cybersecurity functions i.e. identify, protect, detect, respond, recover.
- Implementation Tiers: Various degrees to which NIST CSF has been implemented, partial, risk-informed, repeatable, and adaptive.
- Profiles: Refers to each organization's unique security requirements.



Credit: https://csrc.nist.gov/Projects/cloud-computing/publications

NIST Cloud Computing Resources

NIST has created a dedicated webpage catalog for cloud computing resources which includes various publications, documents, and guidelines related to cloud security.

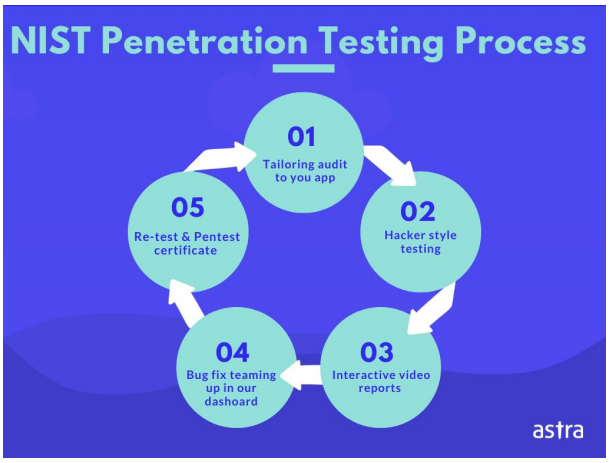
Some of the NIST special publications mentioned in this include

- Cloud Computing Security: Foundations and Challenges, Chapter 7, Managing Risk in the Cloud
- Cloud Computing Security: Foundations and Challenges, Cloud Computing Security Essentials and Architecture

Credit: https://www.getastra.com/blog/compliance/nist/nist-cloud-security/

NIST Cloud Security Best Practices

1. Conduct regular vulnerability assessments and penetration tests
2. Install firewall & anti-malware software
3. Encrypt data at rest and in transit
4. Implement access management controls
5. Have an incident response plan in place



Credit: https://www.getastra.com/blog/compliance/nist/nist-cloud-security/

NIST Cloud Security Benefits

Key benefits of following NIST's cloud security guidelines and standards include:

1. Robust and strong security posture in their cloud environments.
2. Availability of tools and practices provided by NIST to identify and mitigate risks associated with cloud adoption.
3. Aids with regulatory compliance requirements in the cloud for various compliances like SOC2, ISO 27001, PCI-DSS, and more.
4. Provides best practices for increased cloud security and trust in its services.
5. Emphasis on continuous monitoring for prompt detection and response to security threats.
6. NIST is adaptable for various types of cloud deployment be it public, private, community, or hybrid.
7. Optimizes resource usage and cost-effectiveness in securing the cloud.

Credit: https://www.getastra.com/blog/compliance/nist/nist-cloud-security/

Conclusion for NIST Cloud Security

- NIST cloud security resources like standards, frameworks, and resources are invaluable in a landscape where cyber threats are a constant concern.
- Implementing & following NIST's cloud security best practices, and established standards can significantly enhance organizations' cloud security posture & reap its benefits.



Credit: https://www.antivirus.in.th/tips/2316.html

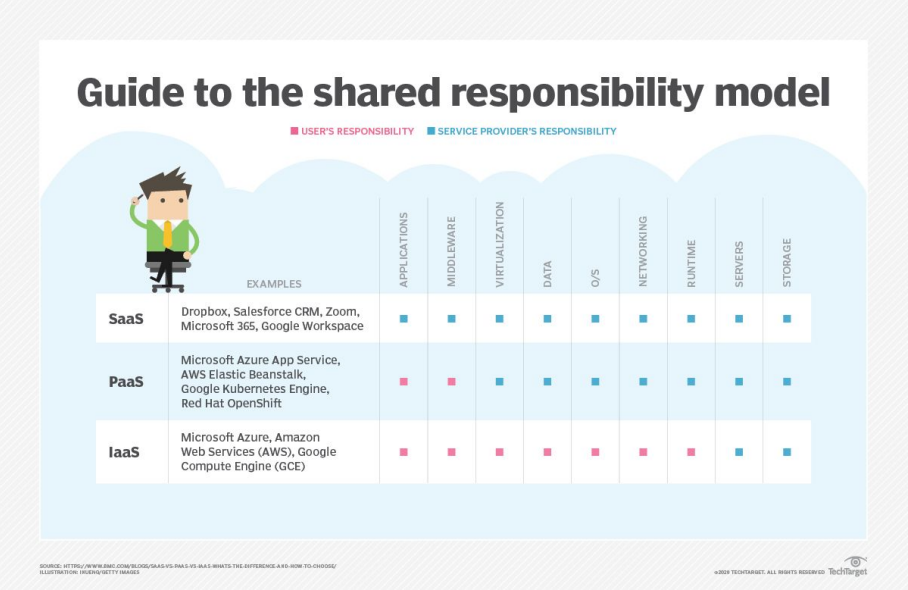
Cloud Security

- ระบบรักษาความปลอดภัยที่จะคอยช่วยปกป้องข้อมูล, แอปพลิเคชัน และโครงสร้างระบบต่าง ๆ ที่อยู่บนคลาวด์ จากการโจมตี และภัยคุกคามทางไซเบอร์
- เทคโนโลยี, นโยบาย, การควบคุม และบริการ ที่มีไว้เพื่อปกป้องข้อมูล, แอปพลิเคชัน, ซอฟต์แวร์ หรือโครงสร้างที่อยู่บนคลาวด์
- เป็นความรับผิดชอบร่วมกันระหว่างผู้ให้บริการ กับลูกค้าที่เป็นผู้ใช้งาน โดยพื้นฐานแล้วจะมีการแบ่งส่วนที่ต้องรับผิดชอบร่วมกันออกเป็น 3 หมวดหมู่ใหญ่ คือ ความรับผิดชอบของฝั่งผู้ให้บริการ, ความรับผิดชอบของฝั่งผู้ใช้ และความรับผิดชอบที่ขึ้นอยู่กับรูปแบบบริการ ที่ได้รับความนิยมก็จะมี Infrastructure as a Service (IaaS), Platform as a Service (PaaS) และ Software as a Service (SaaS)
    - ความรับผิดชอบของฝั่งผู้ให้บริการ
        - เกี่ยวข้องกับระบบป้องกันของตัวโครงสร้างพื้นฐาน อย่างเช่น การเข้าถึงตัวระบบ, การแพทช์ช่องโหว่ด้านความปลอดภัย, การตั้งค่าโฮสต์ และระบบเน็ตเวิร์ค เป็นต้น
    - ความรับผิดชอบของฝั่งผู้ใช้
        - จะเป็นด้านการบริหารจัดการด้านบัญชีผู้ใช้ และสิทธิ์ในการเข้าถึงส่วนต่าง ซึ่งจะต้องมีระบบป้องกันไม่ให้บัญชีที่ไม่ได้รับอนุญาตเข้าถึงพื้นที่นอกเหนือส่วนที่กำหนดสิทธิ์เอาไว้ได้ รวมไปถึงการเข้ารหัสข้อมูล และข้อกำหนดในการเข้าใช้งานต่าง ๆ ด้วย
    - ความรับผิดชอบที่ขึ้นอยู่กับรูปแบบบริการ
        - IaaS (Infrastructure-as-a-Service)
            - เป็นระบบแบบผสม (Hybrid) ที่ทางองค์กรสามารถบริหารข้อมูล และแอปพลิเคชันบางส่วนภายในองค์กรได้ โดยที่อาศัยผู้ให้บริการคลาวด์ในส่วนของการจัดการเซิร์ฟเวอร์, ฮาร์ดแวร์, ระบบเครือข่าย, ระบบจำลอง และพื้นที่เก็บข้อมูลตามที่องค์กรต้องการ
        - PaaS (Platform-as-a-Service)
            - เป็นระบบที่ช่วยเพิ่มความคล่องตัวในการพัฒนาบริการ และแอปพลิเคชันขององค์กร ด้วยการใช้ Custom Application Framework ที่สามารถบริหารระบบปฏิบัติการ, อัปเดตซอฟต์แวร์, พื้นที่เก็บข้อมูล และโครงระบบที่อยู่บนคลาวด์
        - SaaS (Software-as-a-Service)
            - เป็นซอฟต์แวร์บนคลาวด์ที่โฮสต์ข้อมูลเอาไว้บนเซิร์ฟเวอร์ และมักจะมีค่าใช้จ่ายเป็นแบบรายเดือน หรือรายปี โดยที่ผู้ให้บริการซึ่งเป็น 3rd-Party จะคอยดูแลปัญหาทางด้านเทคนิคที่อาจจะเกิดขึ้นให้ทั้งหมด เช่น ข้อมูล, Middleware, เซิร์ฟเวอร์ และพื้นที่เก็บข้อมูล เพื่อลดภาระ และค่าใช้จ่ายของทรัพยากรด้านไอทีขององค์กร และช่วยเพิ่มความคล่องตัวให้กับการบริหารขององค์กรได้ด้วย

Credit: https://www.antivirus.in.th/tips/2316.html

How does Cloud Security work ?

- โมเดลแบบแบ่งความรับผิดชอบร่วมกัน (Shared Responsibility Model)
  - เป็น Framework ที่คอยตีกรอบว่างานรักษาความปลอดภัยส่วนไหนที่เป็นความรับผิดชอบของผู้ให้บริการคลาวด์ และส่วนไหนที่เป็นความรับผิดชอบของทางลูกค้า
  - องค์กรที่ใช้บริการคลาวด์ควรจะต้องมีความเข้าใจถึงความรับผิดชอบของการรักษาความปลอดภัย ว่าส่วนไหนที่ทางองค์กรต้องรับผิดชอบ และส่วนไหนที่องค์กรต้องส่งมอบให้ทางผู้ให้บริการคลาวด์เป็นผู้ดูแลให้ โดยอาศัยการตรวจสอบข้อมูลรายละเอียดกับทางผู้ให้บริการ



Credit: https://www.antivirus.in.th/tips/2316.html

Customer Security Responsibilities (ความรับผิดชอบของฝั่งผู้ใช้)

- เพื่อเติมเต็มระบบรักษาความปลอดภัยนอกเหนือไปจากที่ทางผู้ให้บริการคลาวด์เตรียมเอาไว้ให้ ตามปกติแล้ว ทางผู้ใช้บริการก็จะต้องรับผิดชอบในส่วนของ Application, Middleware, Virtualization, Data, OS, Network และ Runtime Security ใน IaaS Clouds (เช่น Amazon Virtual Private Cloud - AVPC หรือ Microsoft Azure Virtual Network VNet) เป็นต้น
- ในส่วนของ PaaS ผู้ใช้งานจะไม่ต้องรับผิดชอบมากนัก โดยทั่วไปก็มีแค่การรักษาความปลอดภัยในส่วนของแอปพลิเคชัน และ Middleware สุดท้ายคลาวด์ส่วนที่เป็น SaaS ส่วนนี้ผู้ใช้บริการคลาวด์จะไม่ต้องรับผิดชอบอะไรมากนัก
- ความรับผิดชอบของฝั่งผู้ใช้หลัก ๆ ก็จะเป็นด้าน Data Security และ Identity and Access Management อย่างไรก็ตาม มันขึ้นอยู่รูปแบบคลาวด์ที่ใช้งานด้วย เพราะบางรูปแบบ การเข้ารหัสข้อมูล และข้อตกลงในการเข้าใช้งานจะเป็นความรับผิดชอบของลูกค้าด้วย
- องค์กรส่วนใหญ่จะนิยมนำระบบรักษาความปลอดภัยที่ใช้อยู่บนเครือข่าย Local Area Networks (LANs) ที่ใช้อยู่ภายในองค์กรอยู่แล้วไปปรับใช้กับคลาวด์ด้วย ซึ่งจะช่วยให้ทีมผู้ดูแลไม่จำเป็นต้องสร้างนโยบายด้านความปลอดภัยขึ้นมาใหม่ให้ยุ่งยาก

Credit: https://www.antivirus.in.th/tips/2316.html

Cloud Security Tools

- เครื่องมือด้านการรักษาความปลอดภัยที่ถูกใช้ในสภาพแวดล้อมที่อยู่ภายในองค์กรควรถูกนำไปใช้บนคลาวด์ด้วย ถึงแม้ว่าเครื่องมือบางตัวอาจจะมีเวอร์ชันคลาวด์โดยเฉพาะอยู่แล้วก็ตาม เครื่องมือรักษาความปลอดภัยที่มีเฉพาะบนคลาวด์ก็อย่างเช่น
  - Cloud Workload Protections Platforms (CWPPs) : เป็นกลไกรักษาความปลอดภัยที่ออกแบบมาเพื่อปกป้อง Workloads
  - Cloud Access Security Brokers (CASBs) : เป็นเครื่องมือ หรือบริการที่อยู่กึ่งกลางระหว่างลูกค้าที่ใช้คลาวด์ และผู้ให้บริการคลาวด์ เพื่อบังคับใช้นโยบายรักษาความปลอดภัย เปรียบได้กับยามเฝ้าประตู ที่ช่วยเพิ่มการรักษาความปลอดภัยได้อีกหนึ่งชั้น
  - Cloud Security Posture Management (CSPM) : กลุ่มของผลิตภัณฑ์ และบริการด้านความปลอดภัย มีหน้าที่หลายอย่าง ตั้งแต่การคอยตรวจสอบความปลอดภัยบนคลาวด์, แก้ไขปัญหา, ดูแลการตั้งค่าคลาวด์ที่ผิดพลาด ฯลฯ

Credit: https://www.antivirus.in.th/tips/2316.html

Cloud Security Tools (2)

Security as a Service (SeCaaS) เป็นส่วนหนึ่งของ Software as a service ที่ทาง Cloud Security Alliance (CSA) ได้แบ่งเป็น 10 หมวด ดังต่อไปนี้

1. Identity And Access Management (IAM) - เครื่องมือที่ใช้ระบุว่าใคร หรืออะไรที่สามารถเข้าถึงบริการและทรัพยากรในระบบคลาวด์ได้บ้าง และใช้ในการจัดการสิทธิ์อย่างละเอียดได้จากส่วนกลาง
2. Data Loss Prevention (DLP) - ระบบที่ช่วยปกป้องข้อมูลไม่ให้สูญหาย หรือรั่วไหล
3. Web Security - ความปลอดภัยของเว็บไซต์
4. Email Security - ความปลอดภัยของอีเมล
5. Security Assessments - การตรวจหาช่องโหว่ของระบบ
6. Intrusion Management - ระบบจัดการการบุกรุก
7. Security Information and Event Management (SIEM) - เครื่องมือจัดการข้อมูลความปลอดภัย และการจัดการเหตุการณ์ด้านความปลอดภัย เพื่อนำมาวิเคราะห์วางแผน
8. Encryption - การเข้ารหัสข้อมูล
9. Business Continuity and Disaster Recovery (BCDR หรือ BC/DR) - กระบวนการในการกู้ระบบเพื่อให้ธุรกิจสามารถดำเนินการต่อได้ ในกรณีที่ระบบล่ม หรือเกิดความเสียหาย
10. Network Security - ความปลอดภัยของระบบเครือข่าย



Week 15-2
Identity and Access Management (IAM)

06016421 IT Infrastructure Security
by P. Sumet, IT/KMITL

Identity and Access Management

- NIST Identity & Access Management (https://www.nist.gov/identity-access-management)
- NIST Special Publication 800-63 Digital Identity Guidelines (https://www.nist.gov/identity-access-management/nist-special-publication-800-63-digital-identity-guidelines)
- Digital Identity Guidelines (https://csrc.nist.gov/pubs/sp/800/63/4/2pd)

  (https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-63-4.2pd.pdf) ★
- CISSP Domain 5 Identity and Access Management ★ (https://www.dropbox.com/scl/fi/auradi4aeptuwz6wr5sxc/Domain-5-Identity-and-Access-Management.pdf?rlkey=h9ujhl3hf7mjpgryxauhg8xzy&dl=0)